

第 3 课 • SSH + 固定 IP

母题索引 (26 题 → 6 个原理)

| 这是本文件最重要的部分。26 道题本质只有 6 件事；背母题，不背题。 |                                             |                        |
|-------------------------------------|---------------------------------------------|------------------------|
| 母题                                  | 一句话                                         | 覆盖题号                   |
| S1 先定位到哪一段                          | SSH 连接分四段（TCP → 密钥交换 → 主机验证 → 用户认证），报错先归段再查 | 3, 13, 14, 16, 18, 26  |
| S2 密钥认证的信任链                         | 公钥可公开、私钥永不出门；服务器发挑战、私钥签名、公钥验签               | 1, 4, 5, 6, 15, 17, 19 |
| S3 权限即安全边界                          | 谁能写你的 .ssh，谁就能变成你（700/600 + StrictModes）    | 2, 10                  |
| S4 改配置的安全顺序                         | 留后路 → sshd -t → reload → 新窗口验证 → 才关旧窗口      | 7, 9, 12               |
| S5 暴露面控制                            | 要能连、又要只有你能连：密钥认证 + 最小放行 + 封禁                | 8, 11, 22, 24          |
| S6 NAT 与隧道                          | 私网机器不能被主动访问，所以要把连接反向建起来                     | 20, 21, 23, 25         |

考前 48 小时只看这 10 题：1、2、3、7、8、9、13、15、16、21

本课 ★★★ 清单 (13 题，逐条给依据)

| 题号 | 题目                                    | 依据                                                      |
|----|---------------------------------------|---------------------------------------------------------|
| 1  | SSH 免密登录的原理                           | 运维E（认证阶段的检查项与失败定位）                                      |
| 2  | ~/.ssh 700、authorized_keys 600 的原因    | 运维E 已读原文：authorized_keys 应为 600、.ssh 目录为 700            |
| 3  | SSH 连接的四段与对应报错                        | 运维E（按日志特征区分连接阶段/认证阶段）                                   |
| 7  | sshd_config 改完怎么生效（reload vs restart） | 运维E（服务端改配置后重启服务并分析 auth.log）+ 安全G（加固流程）                 |
| 8  | 生产上怎么加固一台公网机器                         | 安全G（fail2ban + Nftables + 云防火墙）、安全H（封禁暴力破解）             |
| 9  | 为什么必须先验证密钥再关密码登录                      | 安全G（加固顺序，先确保密钥可用）                                       |
| 11 | 改 SSH 端口能不能提升安全性                      | 安全H（扫描与暴力破解的真实威胁模型）、安全G                                 |
| 13 | 用户报"SSH 连不上"怎么排查                      | 运维E（"按顺序逐项排查"、"临时简化环境排除法"）                              |
| 14 | Connection refused 与 timed out 的区别    | 运维E（常见故障场景分类：连接阶段 vs 认证阶段）                              |
| 15 | Permission denied (publickey) 怎么排     | 运维E 已读原文：公钥是否在 authorized_keys、权限、私钥是否匹配                |
| 16 | 怎么看 SSH 认证失败的真正原因                     | 运维E 已读原文：LogLevel DEBUG3 + /var/log/auth.log + ssh -vvv |
| 20 | 云服务器连不上 NAT 后的机器怎么办                   | 运维F（隧道是访问内网服务的生产做法）                                     |
| 21 | -L / -R / -D 的区别与场景                   | 运维F（端口转发实战场景）                                           |

第一部分 • 问题清单 (只看这里自测)

格式说明：- [ ] 是自测勾选框（勾上 = 这题一次就答对）；【★★★】是重点标记；加粗数字对应答案区题号。  
组内已按星级从高到低排序：★★★ 必背 → ★★ 理解 → 🐞 生产必会 → ☆ 非面试题。  
本课共 26 题：★★★ 13 | ★★ 10 | 🐞 2 | ☆ 1

A 组 • SSH 原理 (连上之前，先搞懂它怎么认证)

★★★ 3 | ★★ 3 | 共 6 题

- ❑ 1. 【★★★】SSH 免密登录的原理是什么？为什么说它比密码安全？
- ❑ 2. 【★★★】为什么 ~/.ssh 要 700、authorized\_keys 要 600？权限不对会怎样？
- ❑ 3. 【★★★】SSH 连接建立分几个阶段？分别会遇到什么报错？
- ❑ 4. 【★★】ssh-keygen 为什么推荐 ed25519 而不是 RSA？
- ❑ 5. 【★★】known\_hosts 是干什么的？换了机器报 Host key verification failed 怎么处理？
- ❑ 6. 【★★】公钥和私钥分别在谁手里？私钥泄露了怎么办？

B 组 • 服务与配置 (装、启、改、加固)

★★★ 4 | ★★ 1 | 🐞 1 | 共 6 题

- ❑ 7. 【★★★】sshd\_config 改完怎么才能生效？reload 和 restart 有什么区别？
- ❑ 8. 【★★★】生产上你会怎么加固一台公网机器的 SSH？
- ❑ 9. 【★★★】为什么必须"先确认密钥能登录，再关闭密码登录"？
- ❑ 11. 【★★★】把 SSH 端口从 22 改成别的，能提升安全性吗？
- ❑ 10. 【★★】StrictModes 是什么？它和你密钥登录失败有什么关系？
- ❑ 12. 【🐞】怎么查 sshd 当前真正生效的配置（而不是配置文件里写了什么）？

C 组 • 排障场景题 (用户报障，你怎么办)

★★★ 4 | ★★ 3 | 共 7 题

- ❑ 13. 【★★★】用户报"SSH 连不上"，你的排查顺序是什么？
- ❑ 14. 【★★★】Connection refused 和 Connection timed out 有什么区别？各自常见原因？
- ❑ 15. 【★★★】报 Permission denied (publickey) 怎么排？服务端和客户端分别看什么？
- ❑ 16. 【★★★】怎么看到 SSH 认证失败的真正原因？
- ❑ 17. 【★★】密码明明是对的，为什么登录还是失败？

- 18. 【★★】 ssh 连得很慢（卡十几秒才出密码提示），可能是什么原因？
- 19. 【★★】 同一个服务器，A 用户能 SSH 登录、B 用户不能，怎么查？

D 组 · 网络、隧道与场景题

★★★ 2 | ★★ 3 | 1 | ☆ 1 | 共 7 题

- 20. 【★★★★】 云服务器连不上你本地 NAT 后面的机器，怎么解决？
- 21. 【★★★★】 -L / -R / -D 三种端口转发有什么区别？各用在什么场景？
- 23. 【★★】 生产上常用的 ssh 参数和配置有哪些？
- 24. 【★★】 跳板机 / 堡垒机是什么？为什么生产环境不让直连服务器？
- 25. 【★★】 scp、rsync 和 SSH 是什么关系？rsync 为什么快？
- 22. 【🔧】 为什么服务器的 IP 必须固定？IP 变了会连带影响什么？
- 26. 【☆】 为什么运维验证服务要用 curl 而不是打开浏览器？

第二部分 · 参考答案

【★★★★】 1 · SSH 免密登录的原理

- 结论一句话：服务器发一个随机挑战，客户端用私钥签名，服务器用公钥验签。私钥全程不出你的机器。
- 五步展开：
  1. 客户端声明“我是 user，想用这把公钥登录”（带公钥指纹）；
  1. 服务器到 ~/.ssh/authorized\_keys 里找这把公钥 —— 找不到直接拒绝；
  1. 找到后，服务器生成一段随机挑战串发回客户端；
  1. 客户端用私钥对该挑战签名，把签名发回去；
  1. 服务器用公钥验证签名，通过即放行。
- 2. 为什么比密码安全：密码要么在网络上传输、要么在服务器上以哈希形式存着（存在就能被撞库、被复用）；而私钥从不参与网络传输，每次签名都不同（天然防重放），服务器手里根本没有“能冒充你的东西”。
- 3. 加分点：① 生产上私钥要配 passphrase + ssh-agent；② authorized\_keys 里还能限制这把公钥，例如 "from=10.0.0.0/8"、"command=/bin/backup.sh"、"no-port-forwarding" —— "这把钥匙只能从哪来、只能干什么"，这是很吃香的一层。

【★★★★】 2 · 为什么 ~/.ssh 要 700、authorized\_keys 要 600

- 结论：谁能写这些文件，谁就能变成你。权限就是身份边界。
- 逐项原因：

| 对象              | 权限                | 为什么                           |
|-----------------|-------------------|-------------------------------|
| ~/.ssh          | 700               | 目录可写 = 能替换里面的 authorized_keys |
| authorized_keys | 600               | 可写 = 能塞进自己的公钥，直接拿到你的账号        |
| 私钥 id_ed25519   | 600               | 读到私钥 = 身份被冒用                  |
| 家目录             | 不能 group/other 可写 | 家目录可写 = 能把整个 .ssh 换掉          |

- 机制：sshd 默认 StrictModes yes，会校验属主和权限，不合格就直接拒绝密钥登录，且不告诉客户端原因 —— 客户端只看到 Permission denied (publickey)，所以这个坑特别难猜。真正的答案在服务端日志：Authentication refused: bad ownership or modes for file/directory
- 命令：ls -ld ~ ~/.ssh && ls -l ~/.ssh/authorized\_keys；修：chmod 700 ~/.ssh && chmod 600 ~/.ssh/authorized\_keys
- 加分点：如果机器开了 SELinux，还要看上下文（restorecon -R ~/.ssh） —— "权限对了还是进不去"时，这是第二个怀疑对象。

【★★★★】 3 · SSH 连接建立分几个阶段？

- 结论：分四段，每段对应一类报错，这是排障的路线图。

| 阶段            | 发生什么                   | 挂了报什么                                  |
|---------------|------------------------|----------------------------------------|
| ① TCP 连接      | 连对端 22 端口              | Connection refused / timed out         |
| ② 版本协商 + 密钥交换 | 协商算法，DH 交换出会话密钥        | 算法不匹配（老客户端 ↔ 新服务端）                     |
| ③ 主机验证        | 比对 known_hosts 里的服务器公钥 | Host key verification failed           |
| ④ 用户认证        | 密码 / 公钥签名挑战            | Permission denied (publickey/password) |

- 怎么用：看到报错先归段 —— ①② 是网络与传输问题，③④ 是身份问题。方向错了，你可能对着一个健康的 sshd 折腾半小时。
- 加分点：会话建立后还有 channel/PTY（端口转发、scp、rsync 都跑在这条加密通道上）。能说出“认证之后复用通道做转发”，说明你真理解 SSH，而不是只会敲 ssh。

【★★】 4 · 为什么推荐 ed25519 而不是 RSA

- 对比：

|         | ed25519  | RSA       |
|---------|----------|-----------|
| 密钥长度    | 256 位即够用 | 至少 3072 位 |
| 速度 / 体积 | 快、签名短    | 慢、体积大     |
| 现状      | 现代默认     | 仅老设备兼容时用  |

- 为什么：ed25519 基于 Edwards 曲线，安全性对标 3072 位 RSA，同时签名短、验证快、实现上更抗侧信道攻击。

- **加分点：**① `ssh-keygen -t rsa -b 4096` 也不算错（合规要求时常见）；② **DSA 已废弃**，别再用；③ 真正决定安全性的往往不是算法，而是**私钥有没有 passphrase、有没有及时轮换**。

### 【★★】5 • known\_hosts 是干什么的？

- **作用：**存服务器的公钥指纹，首次连接让你确认，之后每次比对 —— 用来**防中间人**（MITM）。
- **报 Host key verification failed 怎么处理：**
  1. **先判断是不是真的换了机器**（重装系统、IP 归属变化、重建实例）—— 这是绝大多数情况；
    1. 通过**另一条可信路径**核对指纹：云控制台、机房、`ssh-keyscan <IP>` 对比；
      1. 确认无误后再删旧记录：`ssh-keygen -R <host>`。
  2. **加分点：别养成“直接删 known\_hosts 了事”的习惯** —— 那等于把防中间人这道门自己拆掉。大规模自动化可用 `StrictHostKeyChecking=accept-new`，但那是“接受首次”，不是“永不校验”。

### 【★★】6 • 公钥和私钥分别在谁手里？私钥泄露怎么办？

- **归属：**公钥放服务器（`~/.ssh/authorized_keys`，可公开）；**私钥只在你本地**（`~/.ssh/id_ed25519`，永不外传）。公钥像“锁”，私钥像“钥匙”；服务器只存锁。
- **泄露后的处理顺序：**
  1. **立刻止血：**从所有服务器的 `authorized_keys` 里移除该公钥；
    1. 轮换：生成新密钥对重新分发，**旧的一律作废**；
      1. 查证据：`/var/log/auth.log` 里有没有异常来源 IP 的登录；
        1. 复盘传播途径（提交到 Git、拷到共享盘、贴进聊天工具……）。
  2. **加分点：私钥提交到 Git 是最常见的泄露方式**。工程上要做的不是“小心点”，而是：每人一把密钥、离职/换设备即轮换、私钥必须有 passphrase、CI 里用**短期凭据**而不是长期私钥。

### 【★★★】7 • sshd\_config 改完怎么生效？reload 和 restart 的区别

- **标准流程：**先语法检查，再 reload —— `sudo sshd -t`（必须无输出）→ `sudo systemctl reload ssh`
- **reload vs restart：**
  - reload：给主进程发信号**重读配置**，不动监听套接字、不杀子进程（**已有会话不受影响**）；
  - restart：停掉再启动。**会不会掐断已有会话，取决于单元里的 KillMode** —— 若是 `control-group`，子进程（也就是你的会话）会被一起停；若是 `process`，会话通常能活。
- **怎么知道你这台机器是哪种**（别背结论，看机器）：`systemctl cat ssh | grep -iE 'KillMode|ExecReload'`
- **加分点：**改监听相关的配置（Port、ListenAddress）后，如果 reload 后 `sudo ss -lntp` 没变化，才需要考虑 restart —— 而且要在“留后路”的前提下做。

### 【★★★】8 • 生产上怎么加固一台公网机器的 SSH？

- **结论：**按四个层面答，比罗列参数更专业。
  1. **认证方式：**只留密钥 —— `PasswordAuthentication no`、`PubkeyAuthentication yes`、禁止空密码；私钥必须带 passphrase。
  1. **账号与权限：**`PermitRootLogin no`（或 `prohibit-password`）、`AllowUsers` 白名单、调小 `MaxAuthTries`、普通用户 `sudo` 提权。
  1. **网络暴露面：**安全组/防火墙**只放行必要来源 IP**，不要长期对 `0.0.0.0/0` 开 22；更严的做法是只允许 VPN 或堡垒机进来。
  1. **持续防护：**`fail2ban` 自动封禁暴力破解；登录日志告警（异常 IP、异常时段）；定期审计 `authorized_keys`。
- 2. **加分点：加固的共同点是“减少入口”，而减少入口就有锁死自己的风险** —— 所以每一步都要遵守“留后路 → 验证 → 再关旧的”（见第 9 题）。

### 【★★★】9 • 为什么必须“先确认密钥能登录，再关闭密码登录”

- **结论：**关掉密码 = 你的**唯一入口只剩密钥**。如果密钥其实还没真正跑通（权限不对、路径不对、agent 没加载），你就**把自己锁在门外** —— 只能靠云控制台 VNC 或进机房插显示器救援。
- **正确顺序（背这五步）：**
  1. **留后路：**另开一个终端并 `sudo -s` 保持登录，不关它；
    1. 备份配置：`sudo cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak`；
      1. 改完语法检查：`sudo sshd -t`；
        1. `sudo systemctl reload ssh`；
    1. **新开一个窗口验证密钥登录成功**，确认后才关掉旧窗口。
  2. **加分点：**这条原则是通用运维铁律 —— **任何“减少入口/收紧权限”的变更，都要先建立并验证新入口，再关闭旧入口**。`sudoers`、防火墙、网络配置全都适用，第 2 周改 `sudoers` 那天就是它的再次实践。

### 【★★★】11 • 改 SSH 端口能提升安全性吗？

- **结论：**不能提升安全性，只能减少扫描噪音。扫描器会扫全端口，不是只扫 22。
- 它确实有的一点作用：挡掉一部分“只扫 22 的自动化机器人”，日志会干净一些。
- **真正的安全来自：**密钥认证 + 最小暴露面（安全组/VPN/堡垒机）+ 封禁（`fail2ban`）+ 及时打补丁。
- **加分点：**改端口的成本却不低 —— 防火墙、监控、资产清单、脚本、`~/.ssh/config` 都要同步改。如果是为了合规要求那照做，但**别把它当安全措施讲**，这是面试官很爱设的陷阱题。

### 【★★】10 • StrictModes 是什么？

- **是什么：**`sshd` 的开关（默认 **yes**），要求用户家目录、`~/.ssh/`、`authorized_keys` 的属主和权限都合格，否则**拒绝密钥认证**。

- 和登录失败的关系：它导致的失败不告诉客户端原因，只在服务端日志留一句 Authentication refused: bad ownership or modes —— 所以"密钥明明对，就是进不去"时，第一个要查的就是它。
  - 怎么办：ls -ld ~ ~/.ssh; ls -l ~/.ssh/authorized\_keys → chmod 700 ~/.ssh && chmod 600 ~/.ssh/authorized\_keys
  - 加分点：不要为了"省事"把 StrictModes 关掉 —— 那等于允许别人通过改写这些文件来冒充你。修权限，不是关检查。
- 【🔧】12 • 怎么查 sshd 当前真正生效的配置
- 命令：sudo sshd -T —— dump 出当前生效的完整配置（含文件里没写、但有默认值的项），配合 grep：  
sudo sshd -T | grep -E 'permitrootlogin|passwordauthentication|port '
  - 还能模拟某个连接：sshd -T -C user=alice,host=web1,addr=10.0.0.5 —— 用来验证 Match 块对特定用户/来源的生效结果。
  - 为什么生产必备：配置文件里"没写" ≠ "没生效"（默认值可能开着），注释掉的旧配置也容易骗人。改配置前先看生效值。
- 【★★★】13 • 用户报"SSH 连不上"，你的排查顺序是什么？
- 先问三个问题，把范围砍一半：① 只有他连不上，还是所有人都连不上？② 一直连不上，还是刚刚才不行？（最近改过什么）③ 本机 ssh localhost 能通吗？
  - 再从外到内五层，每层一条命令：
- | 层      | 命令                                           | 看什么                       |
|--------|----------------------------------------------|---------------------------|
| ① 网络可达 | ping -c 2 <IP> / mtr                         | 通不通、丢包在哪一跳                |
| ② 端口   | nc -zv <IP> 22                               | open 还是 refused / timeout |
| ③ 服务   | systemctl status ssh、`ss -lntp               | grep :22`                 |
| ④ 认证   | sudo tail -30 /var/log/auth.log、ssh -vvv     | 服务端为什么拒绝、客户端卡在哪段          |
| ⑤ 权限   | ls -ld ~ ~/.ssh、ls -l ~/.ssh/authorized_keys | 700/600、属主、SELinux        |
- 加分点：两个实用手法 —— 服务端临时调 LogLevel DEBUG3 再 reload；客户端用 ssh -vvv。还有一招"临时简化环境"：先临时关掉防火墙/SELinux，验证是不是它们的问题（验证完立刻恢复）。
- 【★★★】14 • Connection refused 和 Connection timed out 的区别
- 结论：refused = 对方回话了（说"这个端口没人"）；timed out = 对方根本没回话（包被丢了）。这一个差别，决定你往哪查。
- | 现象                   | 底层发生了什么                        | 常见原因                                     | 往哪查                              |
|----------------------|--------------------------------|------------------------------------------|----------------------------------|
| Connection refused   | 收到 TCP RST / ICMP 端口不可达 —— 有响应 | sshd 没起、监听了别的端口、只监听 127.0.0.1、防火墙 REJECT | 本机：systemctl status ssh、ss -lntp |
| Connection timed out | 包被静默丢弃（DROP） —— 没响应            | 防火墙 DROP、安全组没放行、路由不通、中间设备丢包              | 网络路径：nc -zv、安全组、mtr              |
- 加分点：把这句话说出来就很有说服力 —— "有响应和没响应是两类完全不同的世界：refused 是服务端的事，timeout 是路上或门口的事。"
- 【★★★】15 • 报 Permission denied (publickey) 怎么排？
- 服务端要查的（按命中率排序）：
    - authorized\_keys 里有没有客户端这把公钥（grep -f <(ssh-keygen -y -f 私钥) ~/.ssh/authorized\_keys 或直接对比）；
    - 权限：~/.ssh 700、authorized\_keys 600、家目录不可 group/other 可写；
    - 属主：文件属主必须是这个用户（复制粘贴常常变成 root 属主）；
    - PubkeyAuthentication yes、AllowUsers/AllowGroups 是否包含他；
    - SELinux 上下文（restorecon -R ~/.ssh）；
    - 日志：/var/log/auth.log（Debian/Ubuntu）或 /var/log/secure（RHEL 系）。
  - 客户端要查的：用的是不是那把私钥（ssh -i 或 ssh -v 看 "Offering public key"）、ssh-add -l 看 agent 里有没有加载、用户名对不对。
  - 加分点：两侧一起看才能一次定位 —— ssh -vvv 告诉你"我提了哪把钥匙"，服务端日志告诉你"我为什么拒收"。只盯一侧是新手最常见的耗时方式。
- 【★★★】16 • 怎么看到 SSH 认证失败的真正原因？
- 服务端（真正的答案在这里）：
    - 临时提高日志级别：sudo sed -i 's/^#\?LogLevel.\*/LogLevel DEBUG3/' /etc/ssh/sshd\_config → sudo sshd -t → sudo systemctl reload ssh
    - 盯着看：sudo tail -f /var/log/auth.log（RHEL 系是 /var/log/secure）
    - 验证完记得改回默认级别
    - 客户端：ssh -vvv user@host 2>&1 | tail -40 —— 能看出卡在哪一段（TCP？密钥加载？公钥被拒？）
    - 加分点：DEBUG3 日志量很大、可能包含敏感信息，生产上只临时开、开完就关。能主动说出这个边界，面试官会认为你进过生产。
- 【★★】17 • 密码明明是对的，为什么登录还是失败？
- 先分清两类（这一步最值钱）：
    - 认证被拒：PasswordAuthentication no（服务器只允许密钥）、AllowUsers/DenyUsers 不含他、账户被锁或过期（chage -l、passwd -S）、PAM 的 faillock/pam\_tally 因为多次失败锁定、fail2ban 封了你的 IP。
    - 认证过了但进不去会话：shell 是 /usr/sbin/nologin 或 /bin/false、家目录不存在。
  - 怎么分辨：日志里若出现 Accepted password 紧接着会话异常，就是第二类；否则是第一类。

- **加分点：**Accepted password ... not allowed because shell /usr/sbin/nologin is not executable —— 能引用这句日志原文，证明你真查过这类问题。

【★★】18 • ssh 连接很慢（卡十几秒才出提示），可能是什么原因？

- **第一嫌疑：DNS 反解。**服务端 UseDNS yes 时，sshd 会去反向解析你的 IP，DNS 慢或不可达就干等超时 —— 这是最经典的原因。
- **第二嫌疑：GSSAPI。**服务端/客户端 GSSAPIAuthentication yes 时会先尝试 GSSAPI 协商，环境里没有 Kerberos 就白等一轮。
- **其他：**网络路径有丢包/MTU 问题、服务端负载极高、客户端 ~/.ssh/config 里有不必要的 ProxyJump。
- **怎么确认：**ssh -vvv 看**卡在哪两行之间** —— 卡在服务接受与认证方式列出之间，基本就是 DNS/GSSAPI。
- **修：**服务端 UseDNS no + GSSAPIAuthentication no，客户端也配 GSSAPIAuthentication no，然后 reload。
- **加分点：**回答时先说“我会用 ssh -vvv 确认卡在哪一步，而不是直接猜参数”，这就是排障素养。

【★★】19 • 同一个服务器，A 用户能登录、B 用户不能，怎么查？

- **对比差异（一条条排）：**用户是否存在且未过期、shell 是否可登录、家目录与 ~/.ssh 权限属主、authorized\_keys 内容、组关系、AllowUsers/AllowGroups 白名单、Match 块是否为 B 用户单独设了规则、PAM/faillock 是否锁了 B、是否被 fail2ban 单独封禁。
- **最快的一招：**sshd -T -C user=B,host=<本机名>,addr=<来源IP> —— 直接打印 **B 用户的生效配置**，Match 块的差异一步暴露。
- **加分点：**“能登”和“不能登”是最省力的排查入口 —— **先找差异，再找原因**，比从头查一遍快得多。

【★★★】20 • 云服务器连不上你本地 NAT 后面的机器，怎么解决？

- **结论：**公网机器永远无法主动访问 NAT 后面的私网 IP，所以要让连接从内向外建立。
- **三种做法（按推荐度）：**
  1. **SSH 反向隧道 -R（推荐：零成本、零第三方，本身就是 SSH 技能）**  
云侧：GatewayPorts yes + 安全组放行选定端口；本地：ssh -N -R 10080:localhost:80 root@<公网IP>；之后任何地方访问 http://<公网IP>:10080 就是访问你本地服务。
  1. **组虚拟局域网：**Tailscale / ZeroTier，两边装上即互通，省心但引入第三方。
  1. **内网穿透：**frp / ngrok，企业常见，配置比前两个重。
- **加分点：**① 反向隧道要配 **autossh 或 systemd 保活**（否则断线不重连）；② 说清 GatewayPorts 的安全含义 —— 默认隧道只绑回环，开了才允许外部访问；③ 局域网内用第二台设备验证也算达成，不必非上公网。

【★★★】21 • -L / -R / -D 三种端口转发的区别

- **一句话记忆：**-L 把远端搬到本地，-R 把本地推到远端，-D 在本机开一个动态代理。

| 参数      | 方向         | 典型命令                                       | 生产场景                    |
|---------|------------|--------------------------------------------|-------------------------|
| -L 本地转发 | 远端 → 本地    | ssh -N -L 13306:127.0.0.1:3306 user@dbhost | 数据库端口不对外开，只让运维用隧道连      |
| -R 反向转发 | 本地 → 远端    | ssh -N -R 10080:localhost:80 root@公网IP     | 让公网访问 NAT 后面的服务；第 5 月必用 |
| -D 动态转发 | 本机起 SOCKS5 | ssh -D 1080 user@jump                      | 轻量级“VPN”，浏览器/程序走它出去     |

- **共同点：**都复用同一条 SSH 加密通道，所以不用额外开端口、不怕明文。
- **加分点：**① 加 -N 表示“只做转发不执行命令”，-f 让它转后台，-o ExitOnForwardFailure=yes 让转发失败即退出（否则会“连上了但没转发”）；② 还有 -J（ProxyJump）负责**跳板**，和端口转发是两件事 —— 面试常混着问。

【🔪】22 • 为什么服务器的 IP 必须固定？

- **为什么：**几乎所有配置都**硬编码地址** —— ~/.ssh/config、Ansible 清单、监控抓取目标、安全组放行、脚本变量、known\_hosts、证书 SAN/白名单。IP 一变，报错是“昨天还好、今天全挂”型，最难查。
- **怎么做：**物理机/双系统用**路由器 DHCP 保留**（绑定 MAC → IP，最省事）；虚拟机在虚拟化平台设静态或 netplan 静态 IP（改前先快照）；云上用弹性 IP。
- **加分点：**更好的工程做法是用 **DNS 名字而不是 IP 写脚本** —— 地址变了只改一处 DNS。这就是“用名字解耦地址”的思想，第 3 月的巡检脚本会用到。

【★★】23 • 生产上常用的 ssh 参数和配置有哪些？

- **常用参数：**-p 端口、-i 指定私钥、-J 跳板、-L/-R/-D 转发、-N 不执行命令、-f 转后台、-t 强制分配 TTY、-C 压缩、-v/-vvv 调试、-o ServerAliveInterval=30 保活。
- **~/.ssh/config（生产必备）：**

```
Host web1
  HostName 10.0.0.11
  User ops
  Port 2222
  IdentityFile ~/.ssh/id_ed25519
  ProxyJump bastion
  ServerAliveInterval 30
```

- **加分点：**ControlMaster / ControlPersist 可以**复用同一条连接**（多次 ssh 秒开，Ansible 跑大批任务时提速明显） —— 说出这个，说明你真跑过规模化运维。

【★★】24 • 跳板机 / 堡垒机是什么？为什么不让直连服务器？

- **跳板机：**一台公网可达的中转主机，所有人先登它、再从它进内网。
- **堡垒机：**在跳板机基础上加了**认证、授权、审计**（会话录像、命令记录、临时授权）的平台 —— 属于合规刚需。
- **为什么不让直连：**
  1. **缩小暴露面：**只有跳板机对公网开 22，内网机器不对公网暴露；

- 1. **集中认证与授权**：谁能登哪台、能干什么，统一管；
- 1. **审计留痕**：出了事能回答"谁、什么时候、做了什么"；
- 1. **回收方便**：员工离职只改一处。
- 2. **加分点**：说出"我用 ProxyJump / config 统一走跳板"，等于表明你在有规范的运维环境里工作过；再提一句 SSH CA 签发**短期证书**替代长期私钥，层次立刻不一样。

【★★】25 • scp、rsync 和 SSH 是什么关系？rsync 为什么快？

- **关系**：scp 和 rsync (over ssh) 都**复用 SSH 的加密通道**传文件 —— 所以免密登录配好了，它们也就不需要输密码（第 3 月巡检脚本和备份脚本全靠这个）。
- **rsync 为什么快**：它用**滚动校验**和算法比对两端文件，**只传有差异的数据块**；还支持 -z 压缩、--partial 断点续传、--delete 镜像删除、-a 保留权限与时间、--exclude 排除。
- **scp 的现状**：OpenSSH 9.0 起 scp 底层改用 **SFTP 协议**（老式的 scp 协议有历史漏洞）。
- **加分点**：说清选择标准 —— **少量一次性传输用 scp，大量/重复/需要增量与校验用 rsync**。生产里做目录同步几乎都用 rsync -a --delete。

【☆】26 • 为什么运维验证服务要用 curl 而不是打开浏览器？

- **说明**：这题不是面试题 —— 它是我为了教你习惯加进来的，标 ☆ 就是为了让别把时间花在背它上。
- **但它必须知道**：服务器（尤其最小化安装/P0 环境）**没有浏览器也不该装**；curl -I 只取响应头，快且够用（状态码、Server、Content-Type）；还能脚本化成健康检查 curl -o /dev/null -s -w '%{http\_code}'。
- **对你的直接价值**：双系统下两个系统不能同时开、NAT 下外部也访问不到 —— **curl 是你在本机验证服务的唯一手段**，第 5 月跨机验证也靠它。

第三部分 • 自测记录

| 组  | 内容       | 题量 | 其中 ★★★ | 一次答对 | 需要再练的题号 |
|----|----------|----|--------|------|---------|
| A  | SSH 原理   | 6  | 3      |      |         |
| B  | 服务与配置    | 6  | 4      |      |         |
| C  | 排障场景     | 7  | 4      |      |         |
| D  | 网络、隧道与场景 | 7  | 2      |      |         |
| 合计 |          | 26 | 13     |      |         |

**自测通过标准**：★★★ 那 13 题必须**全部能口述**（SSH 是运维每天用的东西，答不上来会直接被判定为"没实际运维过"）；★★ 能说出思路和第一条命令即可；🔧 会操作就行；☆ 不用背。

附 • 面试官最爱顺着问的三个连环问

- 1. **"SSH 免密怎么配？"** → 追问"原理是什么、私钥为什么不用传过去？" → 再追问"authorized\_keys 权限为什么必须 600？" → 最后问"权限错了报什么错、你怎么定位？"  
(答案链：见 1 → 2 → 10 → 13)
- 1. **"用户说 SSH 连不上。"** → 追问"refused 和 timeout 有什么区别？" → 再追问"怎么看到服务端真正的原因？" → 最后问"如果**全员**都连不上呢？"  
(答案链：见 13 → 14 → 16 → 3)
- 1. **"生产上你怎么加固 SSH？"** → 追问"为什么必须先验证密钥再关密码？" → 再追问"改端口算不算安全措施？" → 最后问"云上怎么只让堡垒机能进？"  
(答案链：见 8 → 9 → 11 → 24)